

User: ursocool

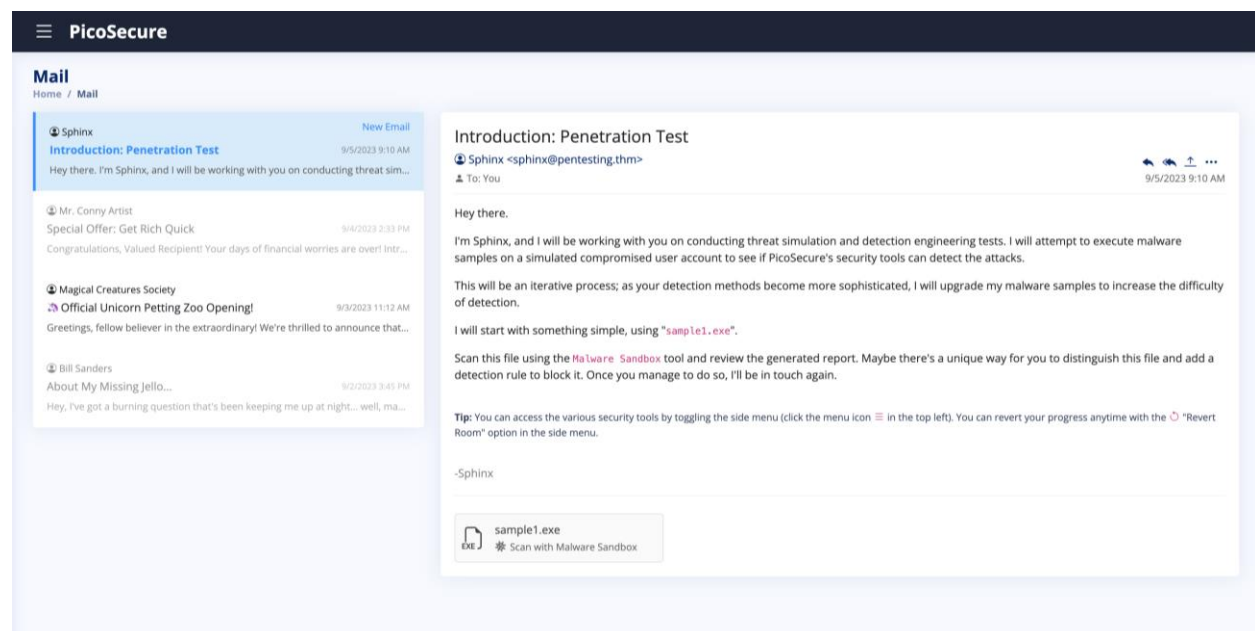
Lab: Summit

Description: PicoSecure has decided to conduct a threat simulation and detection engineering engagement to bolster its malware detection capabilities. You have been assigned to work with an external penetration tester in an iterative purple-team scenario. The tester will be attempting to execute malware samples on a simulated internal user workstation. At the same time, you will need to configure PicoSecure's security tools to detect and prevent the malware from executing.

Following the Pyramid of Pain's ascending priority of indicators, your objective is to increase the simulated adversaries' cost of operations and chase them away for good. Each level of the pyramid allows you to detect and prevent various indicators of attack.

Tools: TryHackMe, IOC Management, EDR, Firewall, Malware Sandbox Tool

1. **Hash Value (Trivial)** – Based on Sphinx's emails, we can determine that we will be starting with the easiest level on the Pyramid of Pain. We can extract the SHA-256 hash(**9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c**) from sandbox analysis of the malware sample sent and use it in the EDR tool by manually adding it to the blocklist as an indicator of compromise (IOC) to strengthen detection and prevention. While this may prevent malware for now, this can be easily bypassed as slightly changing the malware will result in an entirely new hash.



PicoSecure

Malware Sandbox

Home / Malware Sandbox

📁 Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File:

sample1.exe

Submit for Analysis

General Info - sample1.exe

File Name

sample1.exe

File Size

202.50 KB

File Type

PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date

September 5, 2023

OS

Windows 10x64 v1803

Tags

Trojan.Metasploit.A

MIME

application/x-dosexec

MD5

cdba8ae000aa9cbe7c0b982bae006c2a

SHA1

83d2791ca93e58688598485aa62597c8ebbf7610

SHA256

9c558591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c

Behaviour Analysis

MALICIOUS

METASPLOIT was detected

• sample1.exe (PID: 2492)

SUSPICIOUS

Connects to unusual port

• sample1.exe (PID: 2492)

INFO

Reads the machine GUID from the registry

• sample1.exe (PID: 2492)

The process checks LSA protection

• sample1.exe (PID: 2492)

Reads the computer name

• sample1.exe (PID: 2492)

Checks supported languages

• sample1.exe (PID: 2492)

PicoSecure

Manage Hashes

Home / IOC Management / Manage Hashes

🔍 Detect Hashes

Manually add a hash to the blocklist

If you've discovered a hash value related to a malicious file or executable, you can submit it here. Submitted hashes will automatically update PicoSecure's EDR detection signatures and improve its ability to detect and block similar threats.

Hash Algorithm:*

☐ MD5

☐ SHA1

☒ SHA256

Hash Value:*

3cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c

Submit Hash

Hash Blocklist

Algorithm	Value	Actions
MD5	c5a20611630c6dfdf1c2a53fcb00e17	🗑️
MD5	f054bbd2f5ebab9cb5571000b2c50c02	🗑️
SHA1	350930418162cfe2027ab53c99001f0082fed41b	🗑️
SHA256	ed347a07305214ab98974a008674eb78cd03b1fedb73c8be9f79e40fb8e155b0	🗑️
SHA256	b0657d3289bae5be59176613e794ae1bf696c7e2ee529058760fe0b17b0d448f	🗑️
SHA256	cd3c59eedabaa12e1e85068bd687eb23b97aaafdb69b9c7b16a96c2e906aa0bf	🗑️

PicoSecure

Manage Hashes

Home / IOC Management / Manage Hashes

🔍 Detect Hashes

Manually add a hash to the blocklist

If you've discovered a hash value related to a malicious file or executable, you can submit it here. Submitted hashes will automatically update PicoSecure's EDR detection signatures and improve its ability to detect and block similar threats.

Hash Algorithm:^{*}

☐ MD5

☐ SHA1

☒ SHA256

Hash Value:^{*}

Submit Hash

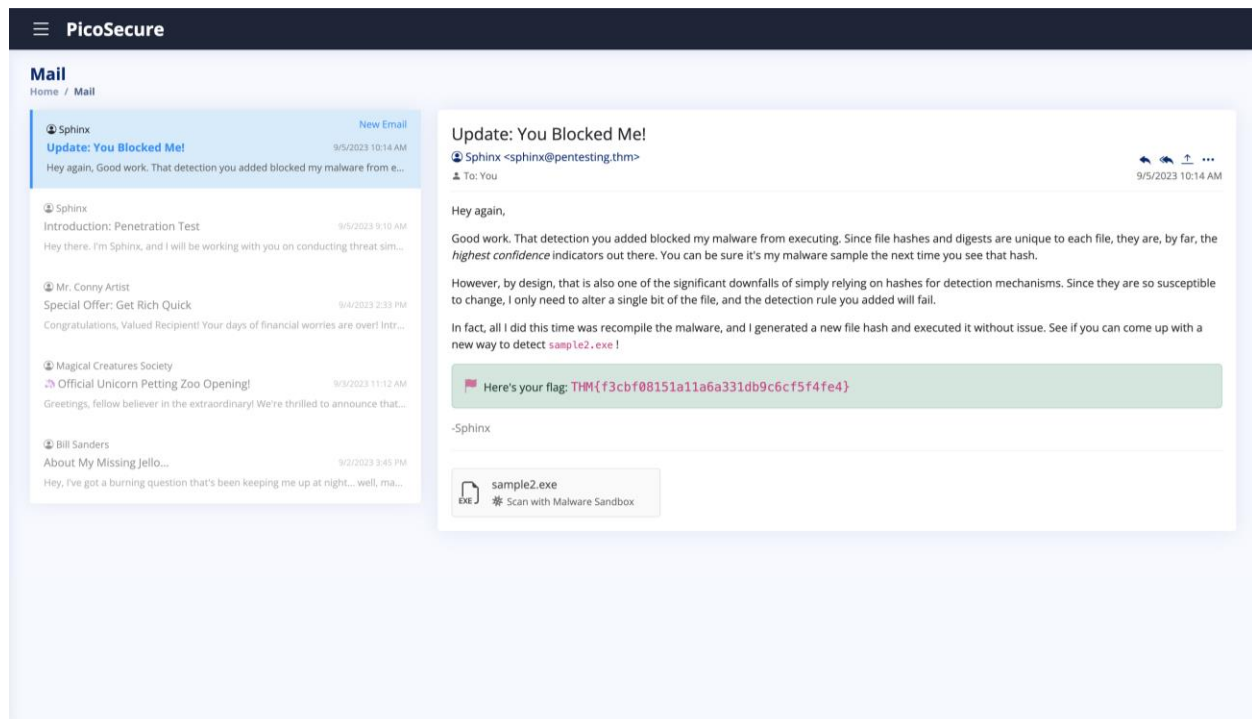
Hash Blocklist

Nice work! You prevented **samp1e1.exe** from executing by detecting its unique hash value. Check your **inbox** for the next steps.

Algorithm	Value	Actions
SHA256	9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c	✔🗑
MD5	c5a20611630c6dfd1f1c2a53fcb00e17	✔🗑
MD5	f054bbd2f5ebab9cb5571000b2c50c02	✔🗑
SHA1	350930418162cfe2027ab53c99001f0082fed41b	✔🗑
SHA256	ed347a07305214ab98974a008674eb78cd03b1feeb73c8be9f79e40fb8e155b0	✔🗑
SHA256	b0657d3289bae5be59176613e794ae1bf696c7e2ee529058760fe0b17b0d448f	✔🗑
SHA256	cd3c59eedabaa12e1e85068bd687eb23b97aaafd869b9c7b16a96c2e906aa0bf	✔🗑

2. **IP Address (Easy)** – Sphinx has sent a second malware sample. When we analyze this sample this time, we see an HTTP request sent to a suspicious IP address (**154.35.10.113:4444**). We can assume that this is the Command-and-Control (C2) server because the malware initiates an outbound connection to an uncommon

external IP over a non-standard port (4444), which is often associated with reverse shells or backdoor communication. As a mitigation step, we can block outbound (egress) traffic to this IP and port at the firewall to prevent infected hosts from communicating with the attacker and exfiltrating data. IP addresses can easily be change through cloud infrastructure, VPNs, and proxy services.



PicoSecure

Malware Sandbox

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File: sample2.exe

Submit for Analysis

General Info - sample2.exe

File Name
sample2.exe

File Size
202.73 KB

File Type
PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date
September 5, 2023

OS
Windows 10x64 v1803

Tags
Trojan.Metasploit.A

MIME
application/x-dosexec

MD5
4d681c1f85e68db15915a5336573a6d4

SHA1
687897687fa27f85af7cf3acc987a2baed7feb975

SHA256
d576245e85e6b752627dfffa43badad152e13835508189f68f924d6ebcc1cf9

Behaviour Analysis

MALICIOUS

Metasploit was detected

- sample2.exe (PID: 1927)

SUSPICIOUS

INFO

Connects to unusual IP address

- sample2.exe (PID: 1927)

The process checks LSA protection

- sample2.exe (PID: 1927)

Reads the machine GUID from the registry

- sample2.exe (PID: 1927)

Checks supported languages

- sample2.exe (PID: 1927)

Connects to unusual port

- sample2.exe (PID: 1927)

Network Activity

HTTP(S) requests

TCP/UDP connections

DNS requests

Threats

1

3

0

0

HTTP requests

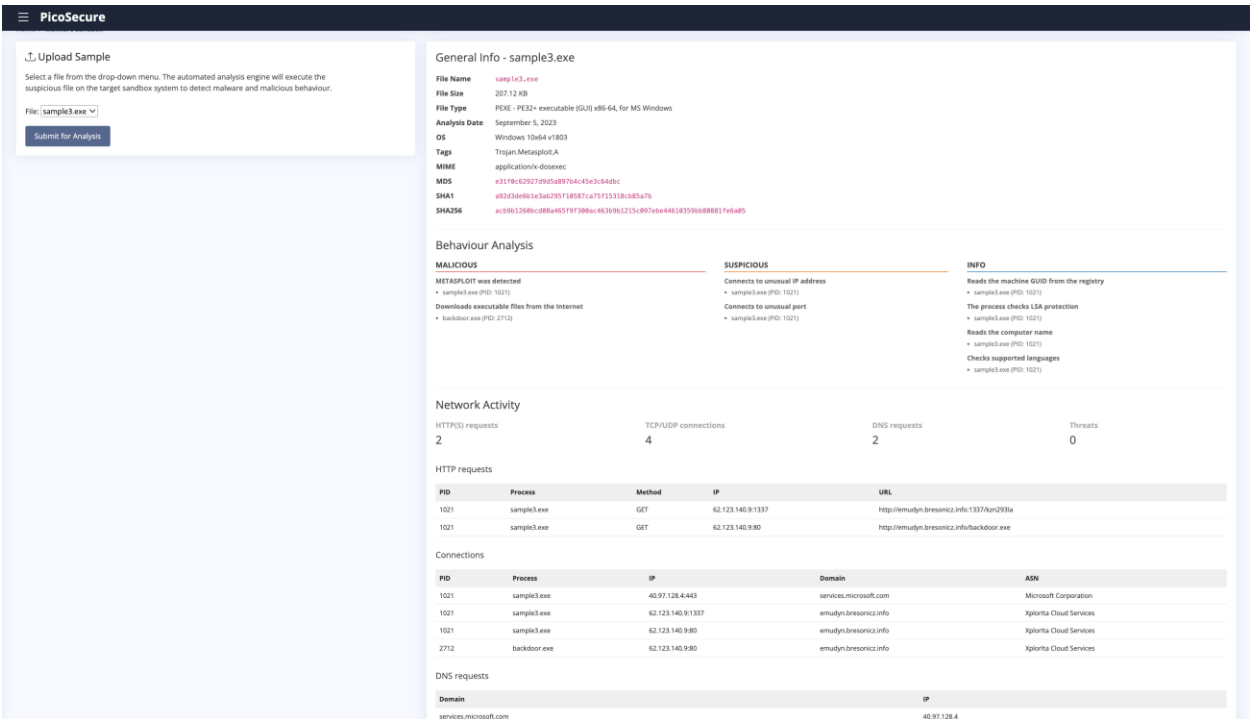
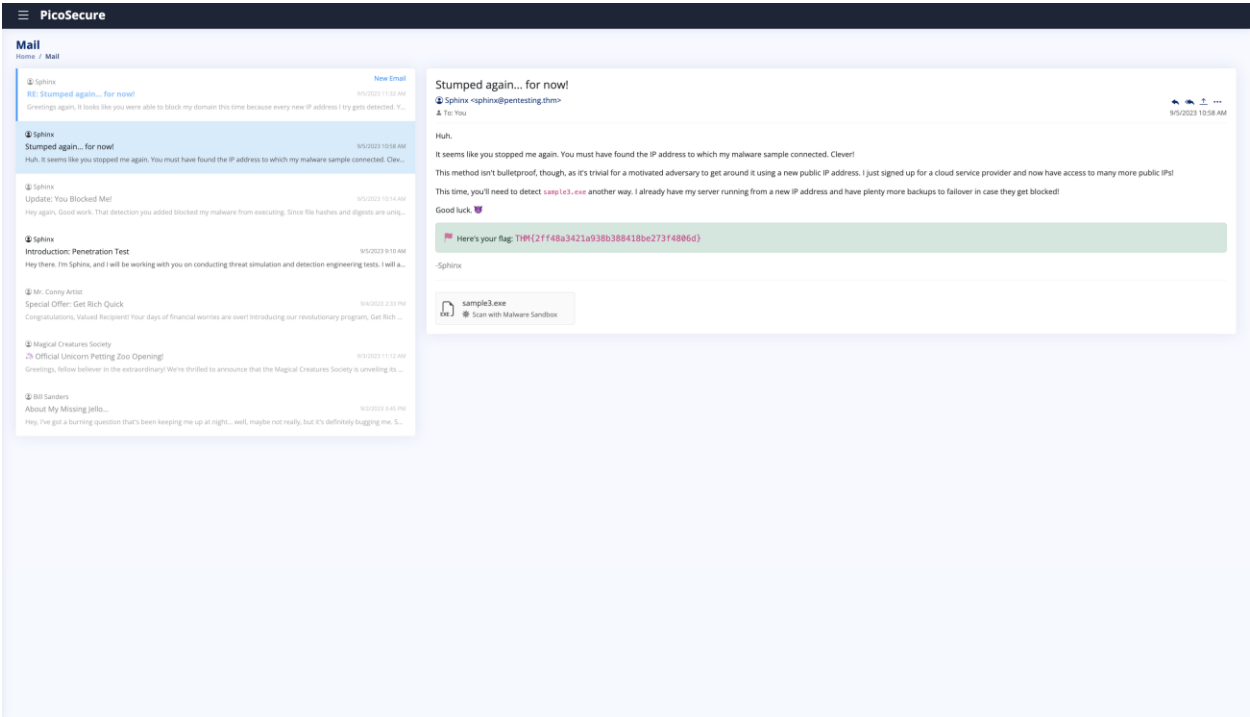
PID	Process	Method	IP	URL
1927	sample2.exe	GET	154.35.10.113-6444	http://154.35.10.113-6444/vulnRyI32

Connections

PID	Process	IP	Domain	ASN
1927	sample2.exe	154.35.10.113-6444	-	Intraflux Hosting Limited
1927	sample2.exe	40.97.128.3-643	-	Microsoft Corporation
1927	sample2.exe	40.97.128.4-643	-	Microsoft Corporation

3. **Domain (Simple)** – Sphinx has sent the third malware sample. When sandboxing our sample, we can see that it sends 2 HTTP requests to the domain emudyn.bresonicz.info. At this point, the IP address is being rotated for C2. We can block this domain to prevent

Sphinx from communicating with its C2 server. However, it is important to remember that Sphinx can still easily change/buy more domains.



The screenshot displays the PicoSecure application window, which provides a comprehensive overview of system security. The interface is organized into several sections:

- Top Bar:** Features the PicoSecure logo on the left and navigation icons (back, forward, search, etc.) on the right.
- Summary Cards:** Located at the top right, these cards provide quick access to key information:
 - Makes changes to the registry:** Shows one instance of sample4.exe (PID: 3806) modifying the registry.
 - Reads the computer name:** Shows one instance of sample4.exe (PID: 3806) reading the computer name.
 - Checks supported languages:** Shows one instance of sample4.exe (PID: 3806) checking supported languages.
- Network Activity:** A section providing insights into network traffic:
 - HTTP(S) requests:** Displays 2 requests.
 - TCP/UDP connections:** Displays 3 connections.
 - DNS requests:** Displays 1 request.
 - Threats:** Displays 0 threats.
 - HTTP requests table:** A detailed log of HTTP requests, including PID, Process, Method, IP, and URL.
 - Connections table:** A detailed log of network connections, including PID, Process, IP, Domain, and ASN.
 - DNS requests table:** A detailed log of DNS requests, including Domain and IP.
- Registry Activity:** A section detailing registry interactions:
 - Total events:** Displays 3 total events.
 - Read events:** Displays 1 read event.
 - Write events:** Displays 2 write events.
 - Delete events:** Displays 0 delete events.
 - Modification events table:** A detailed log of registry modification events, including PID, Process, Operation, Value, Key, Name, and Data.

5. Tools (Challenging) – Instead of a sample, this time we analyze a log file of outgoing connections from the victim machine sent by Sphinx. As we analyze this file, we can see that there are outgoing connections every 30 minutes to the IP address **51.102.10.19**. Additionally, the connection always occurs over port 443 in 97 bytes. Using our observation, we can create another rule in Sigma that detects any connection made every

30 minutes in 97 bytes and map it to MITRE ATT&CK ID Command and Control (TA0011). We don't specify IP address or port as these can be changed very easily by Sphinx.

PicoSecure

Mail

Home / Mail

Sphinx

New Approach

9/5/2023 12:23 PM

New Email

Hey, I'm not sure what you managed to do this time, but you seriously threw a wrench into my malware sample! I spent ages...

Sphinx

RE: Stumped again... for now!

9/5/2023 11:32 AM

Greetings again, it looks like you were able to block my domain this time because every new IP address I try gets detected. Y...

Sphinx

Stumped again... for now!

9/5/2023 10:18 AM

Huh, it seems like you stopped me again. You must have found the IP address to which my malware sample connected. Cle...

Sphinx

Update: You Blocked Me!

9/5/2023 10:14 AM

Hey again, Good work. That detection you added blocked my malware from executing. Since file hashes and digests are uniq...

Sphinx

Introduction: Penetration Test

9/5/2023 9:12 AM

Hey there, I'm Sphinx, and I will be working with you on conducting threat simulation and detection engineering tests. I will a...

Mr. Conny Artid

Special Offer: Get Rich Quick

9/5/2023 8:33 PM

Congratulations, Valued Recipient! Your days of financial worries are over! Introducing our revolutionary program, Get Rich...

Magical Creatures Society

Official Unicorn Petting Zoo Opening!

9/5/2023 11:12 AM

Greetings, fellow believer in the extraordinary! We're thrilled to announce that the Magical Creatures Society is unveiling its...

Bill Sanders

About My Missing Jiffy...

9/5/2023 5:45 PM

Hey, I've got a burning question that's been keeping me up at night... well, maybe not really, but it's definitely bugging me. S...

Sphinx

New Approach

9/5/2023 12:23 PM

Hey,

I'm not sure what you managed to do this time, but you seriously threw a wrench into my malware sample! I spent ages trying to reconfigure my attack tools and methodologies to get around your detection - SUPER ANNOYING!

Having my team develop new techniques used in my adversary tools was a time-consuming effort and a significant cost. It's good that we have a substantial budget for this engagement, but many threat actors would have given up and found a new victim by now.

I finally have [sample.exe](#) for you to detect. Different approach this time. In this sample, all of the "heavy lifting" and instruction occurs on my back-end server, so I can easily change the types of protocols I use and the artifacts I leave on the host. You'll have to find something unique or abnormal about the behaviour of my tool to detect it.

I attached the logs of the outgoing network connections from the last 12 hours on the victim machine. That may help you correlate something.

I don't know what to do if you can stop me at this level.

Here's your flag: `THM{c956f455fc876aea829799c8876ee3993}`

outgoing_connections.log

Open in the Attachment Viewer

Viewing attachment: outgoing_connections.log

2023-08-15 09:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 09:23:45	Source: 10.10.15.12	Destination: 43.10.65.115	Port: 443	Size: 21541 bytes
2023-08-15 09:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 10:14:21	Source: 10.10.15.12	Destination: 87.32.56.124	Port: 80	Size: 1204 bytes
2023-08-15 10:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 11:45:09	Source: 10.10.15.12	Destination: 145.78.90.33	Port: 443	Size: 805 bytes
2023-08-15 12:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 12:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 13:32:17	Source: 10.10.15.12	Destination: 72.15.61.98	Port: 443	Size: 26084 bytes
2023-08-15 14:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 14:55:33	Source: 10.10.15.12	Destination: 208.45.72.16	Port: 443	Size: 45091 bytes
2023-08-15 15:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 15:40:10	Source: 10.10.15.12	Destination: 101.55.20.79	Port: 443	Size: 95021 bytes
2023-08-15 16:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 16:18:55	Source: 10.10.15.12	Destination: 194.92.18.10	Port: 80	Size: 8004 bytes
2023-08-15 16:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 17:09:30	Source: 10.10.15.12	Destination: 77.23.66.214	Port: 443	Size: 9584 bytes
2023-08-15 17:27:42	Source: 10.10.15.12	Destination: 156.29.88.77	Port: 443	Size: 10293 bytes
2023-08-15 17:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 18:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 19:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 19:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 20:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 20:30:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes
2023-08-15 21:00:00	Source: 10.10.15.12	Destination: 51.102.10.19	Port: 443	Size: 97 bytes

PicoSecure

Logs from web servers like Apache or Nginx can provide information about incoming requests, user agents, URLs accessed, and more.

VPN Logs

Logs from virtual private network (VPN) services can show connections and disconnections, user activities, and potential unauthorized access.

Application Logs

Logs generated by various applications can provide insights into their behavior, including errors, authentication attempts, and unusual activities.

Step 2: Sysmon Event Logs

I want to target this Sysmon event:

Process Creation

Detect specific processes being created.

File Creation and Modification

Detect files being created or modified, changes to critical system files, or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autoun, entries, or access control configurations.

Step 3: Network Connections

Set the rule conditions and options:

This rule will detect network connections made from a host machine with specific conditions, such as remote IP, port, size of the connection, and how often it occurs (frequency).

Remote IP:	Any
Remote Port:	Any
Size bytes:	97
Frequency (seconds):	1800
ATT&CK ID:	Command and Control (TA0011)

At PicoSecure, we require that all Sysmon detection rules map to the MITRE ATT&CK framework. This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel Validate Rule

The screenshot displays the PicoSecure Sigma Rule Builder interface, which is used for creating and validating Sigma rules for SIEM systems. The interface is divided into two main sections: the rule creation wizard on the left and the validation details on the right.

Left Panel: Create Sigma Rule

- Step 1: I want to create a rule that focuses on:**
 - ☒ **Sysmon Event Logs**: Sysmon is a Windows system service that monitors and logs various system activities. It provides detailed information about command line activity, process creations, network connections, file creation, and more.
 - ☐ **Web Server Logs**: Logs from web servers like Apache or Nginx can provide information about incoming requests, user agents, URLs accessed, and more.
 - ☐ **VPN Logs**: Logs from virtual private network (VPN) services can show connections and disconnections, user activities, and potential unauthorized access.
 - ☐ **Application Logs**: Logs generated by various applications can provide insights into their behavior, including errors, authentication attempts, and unusual activities.
- Step 2: Sysmon Event Logs**

I want to target this Sysmon event:

 - ☐ **Process Creation**: Detect specific processes being created.
 - ☐ **File Creation and Modification**: Detect files being created or modified, changes to critical system files, or creation of executables or scripts.
 - ☒ **Network Connections**: Detect outgoing network connections, network traffic patterns, or connections made by specific processes.
 - ☐ **Registry Modifications**: Detect changes to registry keys or values such as system settings, security policies, autoun entries, or access control configurations.
- Step 3: Network Connections**

Set the rule conditions and options:

This rule will detect network connections made from a host machine with specific conditions, such as remote IP, port, size of the connection, and how often it occurs (frequency).

Right Panel: Sigma Rule Validation

Your Sigma rule has been validated and automatically deployed to PicoSecure's SIEM system. You can view the rule below:

```

title: Alert on Suspicious Beacon Network Connections
id: network_connections_criteria_sysmon
description: |
  Detects network connections with specific criteria in Sysmon logs: remote IP, remote port, size, and frequency.

references:
  - https://attack.mitre.org/tactics/TA0011/

tags:
  - attack.ta0011
  - sysmon

detection:
  selection:
    EventID: 3
    RemoteIP: 'a'
    RemotePort: '*'
    Size: 87
    Frequency: 1800 seconds

condition: selection

falsepositives:
  - Legitimate network traffic may match this criteria.

level: high
  
```

6. TTP (Tough) – Now we analyze a command log sent by Sphinx. We can see that Sphinx has been sending information by creating a file in the `%temp%` directory, then adding information to it for exfiltration. Knowing this information, we can now create a rule in Sigma that detects file creating and modification with Sysmon Event logs by setting the rule file path to `"%temp%"` and the rule file name to `"exfiltr8.log"`. As we did previously, we map this to MITRE ATT&CK ID Discovery (**TA007**). We have reached the top of the pyramid, and at this point, it is too much effort for Sphinx to continue with their attack.

Mail

Home / Mail

**Sphinx**

RE: New Approach

9/5/2023 1:02 PM

Hello again, You managed to detect sample.exe I'm very impressed. But also very annoyed! Because now, I need to go bac...

**Sphinx**

New Approach

9/5/2023 12:23 PM

Hey, I'm not sure what you managed to do this time, but you seriously threw a wrench into my malware sample! I spent ag...

**Sphinx**

RE: Stumped again... for now!

9/5/2023 11:32 AM

Greetings again, it looks like you were able to block my domain this time because every new IP address I try gets detected. Y...

**Sphinx**

Stumped again... for now!

9/5/2023 10:18 AM

Huh, it seems like you stopped me again. You must have found the IP address to which my malware sample connected. Cle...

**Sphinx**

Update: You Blocked Me!

9/5/2023 10:14 AM

Hey again, Good work. That detection you added blocked my malware from executing. Since file hashes and algos are unq...

**Sphinx**

Introduction: Penetration Test

9/5/2023 9:10 AM

Hey there, I'm Sphinx, and I will be working with you on conducting threat simulation and detection engineering tests. I will a...

**Mr. Conny Artist**

Special Offer: Get Rich Quick

9/4/2023 2:33 PM

Congratulations, Valued Recipient! Your days of financial worries are over! Introducing our revolutionary program, Get Rich ...

**Magical Creatures Society**

Official Unicorns Petting Zoo Opening!

9/5/2023 11:12 AM

Greetings, fellow believer in the extraordinary! We're thrilled to announce that the Magical Creatures Society is unveiling th...

**Bill Sanders**

About My Missing Jello...

9/5/2023 3:41 PM

Hey, I've got a burning question that's been keeping me up at night... well, maybe not really, but it's definitely bugging me. S...

RE: New Approach

 Sphinx <sphinx@pentesting.them>
To: You

9/5/2023 1:02 PM

Hello again,

You managed to detect `sample.exe` I'm very impressed. But also very annoyed! Because now, I need to go back to the drawing board and create a brand new tool to do what I need to do. If I can't find another one quickly, this will be another significant investment. Also, I will need to train myself all over again on how to use it!

I can keep this up one or two times, but there's no way I can continue after this. The reward no longer outweighs the cost, and I would instead find an easier target with detection capabilities much lower on the pyramid.

For my last trick, I have `sample.exe`. This time, you will need more than artifacts or tool detection to help you. You'll need to focus on something extremely hard for me to change subconsciously - my techniques and procedures.

I've attached the recorded command logs from all my previous samples to understand better what actions I tend to perform on my victims to extract info once I have remote access. Good luck!

🚩 Here's your flag: `THM(46b21c4418e47dc5729ceade10fc722e)`

Very Annoyed Sphinx! 🐉

 **commands.log**
Open in the Attachment Viewer

Viewing attachment: `commands.log`

```
dir c:\ >> %temp%\exfiltr8.log
dir "c:\Documents and Settings" >> %temp%\exfiltr8.log
dir "c:\Program Files\" >> %temp%\exfiltr8.log
dir d:\ >> %temp%\exfiltr8.log
net localgroup administrator >> %temp%\exfiltr8.log
ver >> %temp%\exfiltr8.log
systeminfo >> %temp%\exfiltr8.log
ipconfig /all >> %temp%\exfiltr8.log
netstat -ano >> %temp%\exfiltr8.log
net start >> %temp%\exfiltr8.log
```

≡ PicoSecure

Symon is a Windows system service that monitors and logs various system activities. It provides detailed information about command line activity, process creations, network connections, file creation, and more.

Web Server Logs

Logs from web servers like Apache or IIS can provide information about incoming requests, user agents, URLs accessed, and more.

VPN Logs

Logs from virtual private network (VPN) services can show connections and disconnections, user activities, and potential unauthorized access.

Application Logs

Logs generated by various applications can provide insights into their behavior, including errors, authentication attempts, and unusual activities.

Step 2: Symon Event Logs

I want to target this Symon event:

Process Creation

Detect specific processes being created.

File Creation and Modification

Detect files being created or modified, changes to critical system files, or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: File Creation and Modification

Set the rule conditions and options:

File Path:	%temp%
File Name:	exfiltr8.log
ATT&CK ID:	Discovery (TA0007)

All PicoSecure rules require that all Symon detection rules map to the MITRE ATT&CK framework. This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Sigma Rule Builder

Home / SIG Management / Sigma Rule Builder

Create Sigma Rule

Step 1

I want to create a rule that focuses on:

Symon Event Logs

Symon is a Windows system service that monitors and logs various system activities. It provides detailed information about command line activity, process creations, network connections, file creation, and more.

Web Server Logs

Logs from web servers like Apache or Nginx can provide information about incoming requests, user agents, URLs accessed, and more.

VPN Logs

Logs from virtual private network (VPN) services can show connections and disconnections, user activities, and potential unauthorized access.

Application Logs

Logs generated by various applications can provide insights into their behavior, including errors, authentication attempts, and unusual activities.

Step 2: Symon Event Logs

I want to target this Symon event:

Process Creation

Detect specific processes being created.

File Creation and Modification

Detect files being created or modified, changes to critical system files, or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autoun entries, or access control configurations.

Step 3: File Creation and Modification

Set the rule conditions and options:

File Path: %temp%\
File Name: exfiltr*.log

Sigma Rule Validation

Congrats on completing Summit! Check your inbox for the final flag!

Your Sigma rule has been validated and automatically deployed to PicoSecure's SIEM system. You can view the rule below:

```
title: Alert on Potential Exfiltration through File Creation or Modification
id: symon_file_creation_modification_temp
description: |
  Detects file creation or modification events with specific criteria: file path and file name.

references:
  - https://attack.mitre.org/techniques/TAB008/

tags:
  - attack.t0010
  - attack.exfiltration
  - attack.file_creation
  - attack.file_modification
  - symon

detection:
  selection:
    - EventID: 2
      TargetFilename: '.*\\exfiltr*.log'
      TargetPath: '%SystemDrive%\\temp\\*'

  condition: selection

falsepositives:
  - Legitimate use of file creation and modification in a user's temp folder.

level: high
```

You've got mail
New email from: Sphinx

Mail

Home / Mail

Sphinx New Email
I'm Giving Up 9/5/2023 2:42 PM
Well, that's it. I have officially given up. Throughout the engagement, you managed to chase me to the very top of the Pyramid of Pain, and I have to say, it's not fun up here! ...

Sphinx 9/5/2023 1:01 PM
RE: New Approach
Hello again, You managed to detect sample.exe I'm very impressed. But also very annoyed! Because now, I need to go back...

Sphinx 9/5/2023 12:22 PM
New Approach
Hey, I'm not sure what you managed to do this time, but you seriously threw a wrench into my malware sample I spent ages...

Sphinx 9/5/2023 11:32 AM
RE: Stumped again... for now!
Greetings again, It looks like you were able to block my domain this time because every new IP address I try gets detected. Y...

Sphinx 9/5/2023 10:38 AM
Stumped again... for now!
Huh. It seems like you stopped me again. You must have found the IP address to which my malware sample connected. Clea...

Sphinx 9/5/2023 10:14 AM
Update: You Blocked Me!
Hey again, Good work. That detection you added blocked my malware from executing. Since file hashes and digests are unus...

Sphinx 9/5/2023 9:11 AM
Introduction: Penetration Test
Hey there, I'm Sphinx, and I will be working with you on conducting threat simulation and detection engineering tests. I will a...

Mr. Conny Actel 9/4/2023 2:33 PM
Special Offer: Get Rich Quick
Congratulations, Valued Recipient! Your days of financial worries are over! Introducing our revolutionary program, Get Rich ...

Magical Creatures Society 9/5/2023 11:12 AM
Official Unicorn Peeking Zoo Opening!
Greetings, fellow believer in the extraordinary! We're thrilled to announce that the Magical Creatures Society is unveiling th...

Bill Sanders 9/5/2023 9:45 PM
About My Missing Jello...
Hey, I've got a burning question that's been keeping me up at night... well, maybe not really, but it's definitely bugging me. S...

I'm Giving Up

Sphinx: sphinx@pentesting.them
To: You

Well, that's it. I have officially given up.

Throughout the engagement, you managed to chase me to the very top of the Pyramid of Pain, and I have to say, it's not fun up here!

You detected my samples file hashes, IPs, domains, host artifacts, tools, and now my own behavioural techniques! To continue, I have no choice but to completely retrain myself and conduct extensive research to figure out how you're catching me. And with that, I don't think you'll ever see me again. Enjoy the final flag, you've earned it!

Here's your flag: **THM(c8951b2a024bbcbac60c16cf2c83d92c)**

-A significantly defeated Sphinx!